

INFORME DE PENTESTING

TryHackMe · Actividad A08 · Kali Linux en VirtualBox

Cliente	INSECUR S.A. (escenario académico de la guía)
Contratista	Alessandro Faggionato
DNI	44309510
Usuario TryHackMe	alefaggionato
Correo de contacto	alefaggionato@gmail.com
Núcleo obligatorio	Pentesting Fundamentals y Basic Pentesting
Sala de elección	Nmap (Further Nmap)
Branch de entrega	Faggionato-Alessandro
Fecha de inicio	07/10/2026
Fecha de cierre de pruebas	08/10/2026

Resumen ejecutivo

Se completaron las tres salas previstas por la actividad: **Pentesting Fundamentals**, **Basic Pentesting** y **Nmap (Further Nmap)**. Las pruebas se efectuaron en entornos temporales asignados por TryHackMe desde Kali Linux ejecutado en VirtualBox.

En Basic Pentesting se identificó un listado público del directorio **/development/** y un recurso compartido SMB anónimo que permitía leer **staff.txt**. En Nmap se verificó el funcionamiento de escaneos TCP y Xmas y la autenticación FTP anónima en un servidor de laboratorio.

Se documentan **dos hallazgos de severidad media** y **una observación de riesgo bajo, provisional**. Esta última requiere validación adicional de permisos y archivos accesibles: el inicio de sesión FTP anónimo fue aceptado, pero el listado remoto terminó por tiempo de espera. No se atribuyen CVE sin evidencia suficiente.

La evidencia de finalización muestra el perfil de TryHackMe con las tres salas completadas. Las IP indicadas en este informe corresponden a máquinas temporales de laboratorio.

1. Pre-pentesting

1.1 Alcance

Únicamente los laboratorios autorizados de las salas Pentesting Fundamentals, Basic Pentesting y Nmap (Further Nmap) en TryHackMe. El entorno utilizado fue Kali Linux en VirtualBox, conectado por la VPN de la plataforma.

Sala	Equipo y dirección	Actividad registrada
Pentesting Fundamentals	Entorno formativo y conexión VPN	Fundamentos, fases y comprobación de conexión OpenVPN.
Basic Pentesting	Web App Test-bard — 10.64.164.65	Enumeración web/SMB y acceso SSH documentado.
Nmap (Further Nmap)	Further Nmap--badr — 10.67.190.96	ICMP, escaneos de puertos, Wireshark y prueba de FTP anónimo.

1.2 Autorización y reglas de enfrentamiento (ROE)

La guía de la cátedra autoriza exclusivamente la actividad en salas y máquinas temporales de TryHackMe. Quedan excluidos sistemas productivos, redes externas y servicios de terceros. Se evita publicar contraseñas, tokens, claves privadas y flags completas; se conserva únicamente la evidencia pertinente.

Las pruebas de autenticación se limitan a lo requerido por las salas; no se documentan acciones de explotación sobre el objetivo de Further Nmap, destinado al aprendizaje del escaneo. Horarios y límites de tráfico específicos adicionales: no se consignaron en el material aportado.

1.3 Metodología y herramientas

Se siguió la secuencia didáctica de la **Guía A08**: definición de alcance, reconocimiento, escaneo/ enumeración, validación de hallazgos, análisis de riesgos y reporte. Esta estructura es coherente con las etapas generales descritas en NIST SP 800-115; no se afirma una auditoría integral bajo dicho estándar.

Herramienta	Motivo de selección
OpenVPN	Conectar Kali con las máquinas autorizadas de TryHackMe.
Nmap	Enumerar puertos TCP y verificar el comportamiento de técnicas de escaneo.
Gobuster, smbclient, enum4linux	Enumeración web y SMB en Basic Pentesting, según bitácora previa.
Wireshark	Observar el establecimiento de una conexión TCP en tun0.
Script NSE ftp-anon	Verificar si el FTP de la sala acepta autenticación anónima.

2. Ejecución del trabajo

2.1 Pentesting Fundamentals

Se completó la sala sobre metodología y fases del pentesting. Se estableció la conexión VPN de TryHackMe; en la evidencia previa, OpenVPN informó **Initialization Sequence Completed** el 08/10/2026 a las 14:25:30.

Evidencia: evidencias/post/pentesting_fundamentals_completado_vpn.png

2.2 Basic Pentesting

Reconocimiento y escaneo. Se activó Web App Test-bard (10.64.164.65). El escaneo inicial identificó 22/tcp SSH (OpenSSH 8.2p1), 80/tcp HTTP (Apache 2.4.41), 139/tcp y 445/tcp SMB (Samba smbd 4).

```
nmap -sC -sV -oN ~/Downloads/basicpentesting_nmap_inicial.txt 10.64.164.65
```

Enumeración web. Gobuster encontró la ruta **/development/** (301), que presentaba índice de directorio y mostraba **dev.txt** y **j.txt**.

Enumeración SMB. Se listaron recursos compartidos y se accedió sin credenciales al recurso **Anonymous**, desde el cual se pudo descargar **staff.txt**. El archivo mencionaba a Jan y estaba firmado por Kay. enum4linux registró acceso de sesión sin credenciales.

Acceso. Se estableció una sesión SSH como **kay** y se completó la sala. Se comprobó el acceso remoto con la cuenta kay en la VM de práctica.

Referencias de evidencia: evidencias/escaneo/basicpentesting_nmap_10.64.164.65.png;
evidencias/escaneo/basicpentesting_gobuster_10.64.164.65.png;
evidencias/reconocimiento/basicpentesting_directorio_development.png;
evidencias/reconocimiento/basicpentesting_staff_txt.png; evidencias/post/basic_pentesting_completado.png.

2.3 Nmap (Further Nmap): objetivo y conectividad

Se inició la VM **Further Nmap--badr**, con IP asignada **10.67.190.96**. Kali presentaba la interfaz VPN **tun0** con dirección **192.168.151.153**; la ruta hacia el objetivo utilizaba tun0. Cuatro solicitudes ICMP no recibieron respuesta, aunque un escaneo TCP Connect confirmó el puerto 80 abierto.

```
ping -c 4 10.67.190.96  
nmap -Pn -sT -p 80 10.67.190.96
```

Resultado observado: 4 paquetes ICMP transmitidos, 0 recibidos; TCP 80/tcp **open** (HTTP). No se concluye que la ausencia de ICMP demuestre por sí sola la presencia de un firewall.

2. Ejecución: escaneos y comprobaciones de Nmap

2.4 Escaneo Xmas: primeros 999 puertos

`sudo nmap -sX -Pn -p 1-999 --reason 10.67.190.96`
Nmap informó **999 open|filtered tcp ports (no-response)** en 207,94 segundos. La etiqueta **open|filtered** indica indeterminación: no equivale a afirmar que los 999 puertos están abiertos.

2.5 Escaneo TCP SYN: primeros 5000 puertos

`sudo nmap -sS -Pn -p 1-5000 --reason -oN ~/nmap_syn_5000.txt 10.67.190.96`

Puerto	Servicio nominal	Estado / respuesta
21/tcp	FTP	open — syn-ack
53/tcp	domain (DNS)	open — syn-ack
80/tcp	HTTP	open — syn-ack
135/tcp	msrpc	open — syn-ack
3389/tcp	ms-wbt-server (RDP)	open — syn-ack

El escaneo finalizó en **27,03 segundos**. Se detectaron **5 puertos abiertos** y **4995 puertos filtrados** sin respuesta. Los nombres de servicios corresponden a las asociaciones que informa Nmap; no constituyen verificación independiente de la aplicación que escucha.

2.6 Observación del TCP handshake con Wireshark

`nmap -sT -Pn -p 80 10.67.190.96`
En la captura de la interfaz tun0, filtrada por la IP del objetivo y TCP/80, se observaron las secuencias **SYN** → **SYN/ACK** → **ACK** y luego **RST/ACK** desde Kali. Esto respalda que el puerto 80 aceptó una conexión TCP.

2.7 Verificación de FTP anónimo mediante NSE

`nmap -sV -p 21 --script=ftp-anon -Pn 10.67.190.96`
Nmap identificó **FileZilla ftpd 0.9.60 beta** en 21/tcp y reportó **Anonymous FTP login allowed (FTP code 230)**. La consulta de listado de directorio terminó con **TIMEOUT**; por ello, no se verificaron contenidos descargables ni permisos efectivos sobre archivos. La salida indicó Windows como información del servicio, sin que esto equivalga a una identificación concluyente del sistema operativo.

3. Hallazgos — Basic Pentesting

H-01 · Listado público de /development/

Fase	Reconocimiento y escaneo
Descripción	Ruta HTTP /development/ con índice de directorio, dev.txt y j.txt visibles.
Componente	Servidor web Apache, 10.64.164.65:80
Categoría / CVE	CWE-548 (exposición mediante listado de directorios). Sin CVE específico atribuido.
Severidad estimada	Media (cualitativa; no es puntuación CVSS calculada).
Evidencia / herramienta	Gobuster + navegador: evidencias/escaneo/basicpentesting_gobuster_10.64.164.65.png; evidencias/reconocimiento/basicpentesting_directorio_development.png.
Impacto CIA	Confidencialidad: revelación de nombres de archivos y estructura del sitio.
Salvaguarda	Desactivar el listado de directorios y restringir acceso a archivos de desarrollo.
Riesgo residual	Bajo, si se aplica y verifica el control propuesto.

H-02 · Recurso SMB anónimo con acceso a staff.txt

Fase	Reconocimiento y enumeración
Descripción	El recurso Anonymous permite listar y descargar staff.txt sin credenciales.
Componente	Servicio SMB, 10.64.164.65:139/445
Categoría / CVE	CWE-552 (archivos o directorios accesibles a partes externas). Sin CVE específico atribuido.
Severidad estimada	Media (cualitativa; no es puntuación CVSS calculada).
Evidencia / herramienta	smbclient + enum4linux: evidencias/reconocimiento/basicpentesting_anonymous_ls.png, basicpentesting_staff_txt.png y basicpentesting_enum4linux_U.png.
Impacto CIA	Confidencialidad: lectura no autenticada de información del personal.
Salvaguarda	Exigir autenticación si no se necesita acceso público y aplicar mínimos privilegios.
Riesgo residual	Bajo, tras restringir permisos y verificar el acceso.

3. Hallazgos — Nmap y resumen

H-03 · Autenticación FTP anónima permitida (observación)

Fase	Escaneo y validación de configuración
Descripción	El script ftp-anon obtuvo el mensaje “Anonymous FTP login allowed (FTP code 230)”. No se pudo listar el directorio: TIMEOUT.
Componente	FTP en 10.67.190.96:21; Nmap detectó FileZilla ftpd 0.9.60 beta.
Categoría / CVE	Acceso anónimo FTP confirmado; no se atribuye CWE ni CVE sin validar el propósito y los permisos del servicio.
Severidad estimada	Baja, provisional. El acceso anónimo no demuestra por sí solo exposición no autorizada.
Evidencia / herramienta	Script NSE ftp-anon: evidencias/escaneo/nmap_ftp_anonymous.png.
Impacto CIA	Confidencialidad potencial; no se comprobó lectura, escritura ni descarga de archivos.
Salvaguarda	Confirmar si el acceso público es intencional; de no serlo, deshabilitar Anonymous y revisar permisos.
Riesgo residual	Bajo sujeto a comprobación de configuración y permisos.

4. Resumen cuantitativo de hallazgos

Severidad	Cantidad	Hallazgos
Crítica	0	—
Alta	0	—
Media	2	H-01, H-02
Baja (provisional)	1	H-03
Total	3	Dos hallazgos y una observación

La clasificación es cualitativa. No se calcularon puntajes CVSS numéricos por falta de parámetros comprobados suficientes. Los puertos abiertos y el resultado de un Xmas Scan no constituyen hallazgos independientes.

5. Post-pentesting: recomendaciones

5.1 Recomendaciones técnicas (por prioridad)

- H-02 (media).** Restringir el recurso SMB Anonymous, aplicar permisos mínimos y verificar el acceso a staff.txt.
- H-01 (media).** Desactivar el índice de /development/, proteger sus archivos y comprobar el control.
- H-03 (baja, provisional).** Confirmar si se requiere FTP anónimo; desactivarlo si no es necesario o limitar su contenido y permisos si es intencional.

5.2 Recomendaciones administrativas

- Realizar revisiones periódicas de recursos compartidos y contenido publicado antes de desplegar cambios.
- Registrar responsables de remediación, evidencia de pruebas de verificación y resultados posteriores.
- Reforzar criterios de publicación y políticas de permisos para web, SMB y FTP.

Las medidas propuestas no se aplicaron en los laboratorios. No se verificaron permisos sobre archivos FTP.

6. Protocolo de contingencia

6.1 Escenario e impacto sobre el negocio

Escenario hipotético: un cambio de seguridad o una prueba interrumpe un servicio web, SMB o FTP. Se verían afectadas las consultas web o las transferencias de archivos; el tiempo real de interrupción no se conoce.

6.2 Plan de respuesta

Etapa	Acción prevista
Activación	Detectar pérdida de disponibilidad o degradación; confirmar servicio afectado y registrar hora del incidente.
Contención (0-15 min)	Detener pruebas y cambios, preservar registros y avisar al responsable del servicio.
Recuperación	Restablecer última configuración validada o respaldo; comprobar conectividad y permisos antes de reabrir.
Comunicación	Notificar a responsables técnicos y dirección; informar usuarios afectados si corresponde.
Post-mortem	Registrar causa, tiempos reales, cambios aplicados y acciones preventivas.

6.3 RTO y RPO estimados

RTO (propuesta)	4 horas (hipótesis académica, no acordada con el cliente).
RPO (propuesta)	24 horas (hipótesis académica; depende de respaldos y debe validarse).

7. Anexos y declaración ética

Anexo A · Bitácora de comandos

Los registros de las prácticas se encuentran en **bitacora/basic_pentesting_20261008.txt** y **bitacora/nmap_20261008.txt**. La salida original del escaneo SYN se conserva en **bitacora/nmap_syn_5000.txt**. El archivo registra los primeros 5000 puertos TCP del objetivo 10.67.190.96.

Anexo B · Inventario de evidencias de Further Nmap

Fase	Archivo de evidencia
Reconocimiento	evidencias/reconocimiento/nmap_conectividad.png
Escaneo	evidencias/escaneo/nmap_puerto_80.png
Escaneo	evidencias/escaneo/nmap_xmas_scan.png
Escaneo SYN	bitacora/nmap_syn_5000.txt (salida original de Nmap)
Escaneo	evidencias/escaneo/nmap_tcp_connect_wireshark.png
Escaneo	evidencias/escaneo/nmap_ftp_anonymous.png
Post	evidencias/post/nmap_sala_completada.png

Las rutas anteriores corresponden a los archivos incluidos para la entrega. La salida original del escaneo SYN se conserva en **bitacora/nmap_syn_5000.txt**.

Declaración ética

Declaro que todas las actividades fueron realizadas dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Fuentes

Guía práctica + plantilla A08 (archivo provisto por la cátedra); Cuadernillo de Clase 7 (material de seguridad lógica y herramientas Kali); manual de Nmap (nmap -h y <https://nmap.org/book/man.html>); TryHackMe (salas completadas); MITRE CWE-548 y CWE-552 (referencias de clasificación).